

Informe de Gestión de Incidentes conforme a ISO 27001

Vulnerabilidad de Inyección SQL (SQL Injection)

Introducción

El presente informe documenta la identificación y explotación de una vulnerabilidad de tipo **SQL Injection** en la aplicación web Damn Vulnerable Web Application (DVWA). La prueba se realizó en un entorno controlado de laboratorio con fines académicos, con el objetivo de demostrar el impacto que puede tener una validación insuficiente de entradas en una aplicación web.

Entorno de Pruebas

La evaluación de seguridad se llevó a cabo utilizando DVWA desplegado en un entorno local controlado.

Para la ejecución de las pruebas se realizaron las siguientes configuraciones:

- Instalación y despliegue de DVWA.
 - Inicialización de la base de datos.
 - Configuración del nivel de seguridad en **Low** para permitir la explotación de vulnerabilidades.
 - Acceso al módulo “SQL Injection” para la realización de pruebas.
-

Descripción del Incidente

Durante la evaluación de seguridad se identificó una vulnerabilidad de **inyección SQL** en el módulo “SQL Injection” de DVWA. Esta vulnerabilidad permite a un atacante manipular consultas SQL mediante la entrada de datos no sanitizados, lo que puede derivar en acceso no autorizado a la base de datos.

El problema se debe a la falta de validación y parametrización de las entradas del usuario antes de ser incluidas en las consultas SQL.

Métodos de Inyección SQL Utilizados

1. Bypass de autenticación (condición siempre verdadera)

```
1' OR '1'='1
```

Resultado obtenido:

El resultado nos indica 5 usuarios, Admin Admin, Gordon Brown, Hack me, Pablo Picasso y Bob Smith

2. Obtención de la versión de la base de datos

```
1' UNION SELECT null, version() #
```

Resultado obtenido:

El resultado nos indica que el sistema operativo es una Debian con MariaDB 11.8.9

3. Obtención del nombre de la base de datos actual

```
1' UNION SELECT null, database() #
```

Resultado obtenido:

El resultado nos indica que la base de datos tiene el nombre de dvwa

Resultados Generales

Las pruebas realizadas demostraron que la aplicación:

- Permite la manipulación de consultas SQL sin restricciones.
- No implementa validación de entrada ni consultas parametrizadas.
- Expone información sensible almacenada en la base de datos.
- Es vulnerable a técnicas de inyección SQL básicas.